

Zico2 Writeups

By: Liul Sintayehu Tebkew

Date : May 10, 2026

- **Step 1: Host Discovery**

- First, I used netdiscover to identify active hosts on the local network.
- During the scan, I found the target machine with the IP address 192.168.71.133.
- My attacker machine IP address was 192.168.71.132.

- **Step 2: Port Scanning and Service Enumeration**

- After identifying the target, I performed an Nmap scan to discover open ports and running services.
- The scan revealed that port 80 was open, indicating that a web server was running on the target machine.

- **Step 3: Web Application Enumeration**

- I opened the target IP address in the browser and began exploring the website manually.
- While navigating through the website, I found a button labeled “**Check.**”
- After clicking the button, I noticed that the URL changed dynamically and appeared to accept user-controlled input.

- **Step 4: Local File Inclusion (LFI) Discovery**

- The URL behavior suggested a possible Local File Inclusion (LFI) vulnerability.
- To test the vulnerability, I attempted to access the /etc/passwd file.
- The application successfully returned the contents of the file, confirming the LFI vulnerability.

- **Step 5: Directory Bruteforcing**

- After confirming the LFI vulnerability, I used Gobuster to brute-force directories and files on the target web server.

- During enumeration, I discovered several routes, including the /dbadmin directory.
- **Step 6: Accessing the Database Administration Panel**
 - I visited the /dbadmin route and found a database administration page called test_db.php.
 - The application required authentication.
 - I attempted to log in using default credentials:
 - Password: admin
 - The login was successful.
- **Step 7: Creating a PHP Backdoor**
 - After gaining access to the database administration interface, I discovered that I could create a database file.
 - I created a file named hack.php.
 - Inside the file, I created a table and row containing a PHP backdoor.
 - The backdoor accepted a cmd parameter from the URL and executed system commands on the target machine.
- **Step 8: Preparing the Reverse Shell**
 - On my attacker machine (192.168.71.132), I started a Netcat listener on port 4444.
 - The listener waited for an incoming reverse shell connection from the target machine.
- **Step 9: Gaining Initial Shell Access**
 - I returned to the target website and used the cmd parameter in the URL to execute a reverse shell payload.
 - The payload connected back to my attacker machine.
 - After executing the payload successfully, I received a reverse shell as the www-data user.
- **Step 10: Enumerating Sensitive Files**

- After gaining shell access, I searched the system for useful configuration files.
- During enumeration, I discovered the wp-config.php file.
- Inside the file, I found credentials that could be used to switch to the zico user.
- **Step 11: Upgrading the Shell**
 - Before switching users, I upgraded the reverse shell into a fully interactive shell using Python PTY.
 - This improved shell stability and allowed interactive commands such as su to function correctly.
- **Step 12: Switching to the Zico User**
 - After stabilizing the shell, I used the discovered credentials to switch to the zico user successfully.
- **Step 13: Privilege Escalation Enumeration**
 - Once authenticated as the zico user, I checked the sudo permissions assigned to the account.
 - I discovered that the user could execute two commands with sudo privileges without requiring a password.
- **Step 14: GTFOBins Privilege Escalation**
 - One of the allowed binaries was tar.
 - I searched GTFOBins for known privilege escalation techniques involving tar.
 - Using the GTFOBins method, I executed the tar command to spawn a root shell.
- **Step 15: Obtaining Root Access**
 - The privilege escalation was successful, and I obtained a root shell on the target machine.
- **Step 16: Capturing the Flag**
 - Finally, I navigated to the /root directory.
 - Inside the directory, I located and retrieved the root flag successfully.